

TECHNICAL PRODUCT GUIDE

AI 기반 IT 자산관리 시스템

자산 수명주기 관리, Shadow IT Discovery, AI 자산 인텔리전스를 단일 플랫폼으로 통합한다.
관리 대장에 있는 자산을 관리하는 것을 넘어, 발견되지 않은 자산을 찾아 대장에 편입시키는
것까지를 관리 범위로 하는 차세대 ITAM 플랫폼 기술 안내서.

- 자산 수명주기 관리
- Shadow IT Discovery
- CMDB 자동 대사
- AI 자산 인텔리전스
- 전자결재 워크플로우

목차

01 시스템 개요

AI 기반 자산관리 통합 플랫폼 · 메뉴 체계 (8대 업무 도메인)

02 플랫폼 아키텍처

4-Tier 시스템 구성 · 배치 구성도 · 권한·접근통제 모델

03 자산관리 모듈

자산 수명주기 관리 · 재고 / 계약 / 라이선스 관리

04 Shadow IT Discovery 모듈

탐지 채널(6종) · CMDB 대사 워크플로 · 외부 공격표면 탐지

05 AI 인텔리전스 모듈

AI 기능 구성(5대 기능) · AI 어시스턴트와 리포트 자동화

06 연동 & 공통 기반

시스템 연동 아키텍처 — 발견 소스와 조치 채널

07 기술 스택 & 보안

기술 스택 · 보안성 · 사양 요약

본 안내서는 검증된 전사 IT 관리 플랫폼 구축 사례를 기반으로 고객사 환경에 맞춘 **기술 구성**을 기술한다. 자산관리·Discovery·AI 전 모듈은 공통 **전자결재**와 **메뉴·기능 권한관리** 기반 위에서 동작하며, Shadow IT 발견부터 정식 자산 편입까지 단일 플랫폼에서 처리된다.

AI 기반 자산관리 통합 플랫폼

IT 자산의 도입·운영·폐기 전 수명주기와 미등록 자산(Shadow IT)의 자동 발견, AI 기반 분석을 **단일 플랫폼**에서 처리한다. 관리 대장에 있는 자산만 관리하는 기존 ITAM과 달리, **"발견되지 않은 자산"을 찾아 대장에 편입시키는 것까지**를 관리 범위로 한다.

MODULE 1

자산관리 (ITAM)

- 자산 대장 · 수명주기(도입~폐기)
- 재고 · 재물조사 · 이동/불출
- 계약 · 유지보수 · 만료 알림
- SW 라이선스 컴플라이언스

MODULE 2

Shadow IT Discovery

- 6종 탐지 채널 자동 수집
- 자산 지문 기반 중복 제거
- CMDB 자동 대사(등록/미등록)
- 소유자 확인 → 편입/격리 워크플로

MODULE 3

AI 인텔리전스

- 자산 자동분류 · 데이터 정규화
- 이상 자산 행위 탐지
- 수명주기 · 교체수요 예측
- 자연어 질의 AI 어시스턴트

운영 주체 ROLE MODEL

권한그룹	역할 / 책임
사용자	본인 보유 자산 조회, 자산 신청·반납·이동 요청 및 결재 상신, 소유자 확인 요청 응답
자산담당	자산 등록·이동·폐기 처리, 재물조사 수행, 발견 자산의 편입 처리
보안담당	Shadow IT 판정·격리 요청, 미인가 SW·SaaS 정책 관리, 위험도 기준 관리
Admin	사용자·권한·메뉴·공통코드·탐지 채널·AI 정책 등 시스템 전반 관리

설계 원칙 — 발견에서 편입까지. 대장에 등록된 자산만 관리하면 사각지대가 생기기 쉽다. 스캔·로그·API로 자산을 상시 발견하고, 발견 자산이 소유자 확인과 결재를 거쳐 대장에 편입되거나 격리되도록 하는 폐쇄 루프를 제공한다.

메뉴 체계 — 8대 업무 도메인

대분류 (LV1)	중분류 (LV2)	주요 화면 (LV3)
Main (Home)	대시보드 · 게시판	자산 현황 요약, 미등록 자산 신규 발견 현황, 만료 임박(계약·라이선스), My Work, 공지·QnA
자산관리	자산 대장	H/W(단말·서버·네트워크) · S/W · 가상자원 대장, 자산번호·구성정보·소유자·위치 이력
	수명주기	도입(검수·등록) · 불출/이동 · 반납 · 유희 · 폐기(결재·증적) 처리
재고·계약	재고 · 재물조사	보유 재고 현황, 재물조사 계획·수행(바코드/QR)·차이 조정
	계약 · 라이선스	구매·유지보수 계약, SW 라이선스 보유/사용 대사, 만료·갱신 알림
Discovery	발견 자산	신규 발견 목록(채널별), 자산 지문·중복 병합, 위험도 분류
	대사 · Shadow SaaS	CMDB 대사 리포트(등록/미등록/불일치), 미인가 SaaS 사용 현황(부서별)
AI 인텔리전스	AI 어시스턴트	자연어 자산 질의·리포트 생성, 발견 자산 AI 요약 브리핑
	분석 · 예측	이상 자산 행위 탐지, 교체수요·수명 예측, 라이선스 최적화 제안
워크플로	신청 · 결재	자산 신청/반납/이동/폐기 상신, 소유자 확인 요청, 격리 요청 결재
환경설정	권한 · 코드 · 정책	사용자·그룹·결재선·메뉴권한, 공통코드, 탐지 채널·스캔 정책, SaaS 카탈로그, AI 정책
기타 (기반)	연동 · 인프라	NAC·EDR·AD·CSP·프록시 연동, 이메일·문자 발송, SSO(SAML), 감사 로그

4-Tier 시스템 구성



그림 1 — AI 자산관리 플랫폼 4-Tier 아키텍처. 강조 표시된 수집·연동 계층이 기존 3-Tier ITAM에 추가된 구조다.

계층별 책임 LAYER RESPONSIBILITIES

계층	구성 · 책임
사용자 계층	SSO 인증 후 부여된 메뉴·기능만 렌더링, 자산·발견 현황 대시보드와 AI 어시스턴트 제공
애플리케이션 계층	자산·재고·계약 업무 모듈, Discovery 대사 엔진, AI 서비스, 공통 전자결재·알림
수집·연동 계층	능동 스캔과 기존 보안·인프라 시스템 API/로그 수집 — 신규 에이전트 배포 없이 시작 가능
데이터 계층	자산 대장(CMDB)과 발견 저장소 분리 — 검증된 자산만 대장 편입, 원천 로그는 증적 보존

배치 구성도 — 온프레미스 기준



그림 2 — 온프레미스 배치 구성. 전 구성요소가 사내에 배치되며, 외부 구간은 선택 구성인 CSP API 아웃바운드 수집뿐이다.

망분리 환경 기본 대응. 웹/WAS · Discovery · AI(GPU) · DB 4개 역할 기준 구성으로, 소규모는 통합 배치, 대규모는 역할별 분리·이중화로 확장한다. AI 서버까지 온프레미스에 두면 자산·구성 정보가 외부로 나가는 구간이 없다.

권한 · 접근통제 모델

메뉴 권한관리 체계 PERMISSION PIPELINE



권한그룹별 기본 접근 범위

권한그룹	접근 범위
사용자	본인 자산 조회·신청
자산담당	자산 등록·이동·폐기·재물조사
보안담당	Discovery 판정·격리·정책
Admin	시스템·권한·코드·AI 정책 관리

기능(Action) 단위 통제

조회

저장

삭제

엑셀

편집

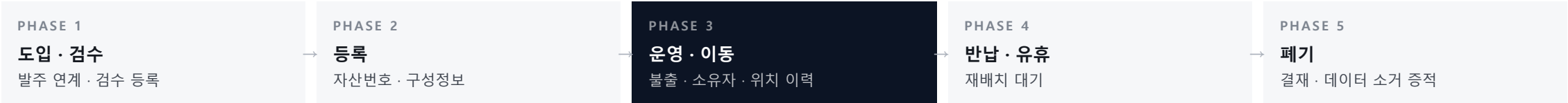
격리요청

결재

- 권한은 **메뉴(화면) × 기능(버튼)** 단위로 부여
- 발견 자산의 **편집·격리**는 **자산담당·보안담당**에게만 노출
- 화면별 **기본 결재선**을 사전 정의 — 폐기·격리는 필수 결재
- AI 어시스턴트 응답도 **사용자 권한 범위 내 데이터만** 조회

화면·기능 단위 최소권한. 사용자에게는 매핑된 메뉴·기능만 노출되며, AI 질의를 포함한 모든 데이터 접근이 동일한 권한 모델을 통과한다. 조회는 가능하되 편집·격리·폐기·결재는 권한이 있는 역할에만 허용된다.

자산 수명주기 관리



화면 구성 SCREENS

화면	기능
자산 대장	H/W(단말·서버·네트워크·주변기기) · S/W · 가상자원(VM·클라우드) 유형별 대장, 구성정보(CPU·메모리·OS·IP·MAC), 소유 부서·사용자, 위치
도입·검수	구매 계약 연계 입고 등록, 검수 체크리스트, 자산번호 채번·라벨(바코드/QR) 발행
불출·이동	사용자 신청 → 결재 → 불출 처리, 부서·위치·사용자 변경 이력 자동 축적
반납·유휴	반납 접수·상태 점검, 유휴 자산 풀 관리(재배치 우선 원칙)
폐기	폐기 대상 선정 → 결재 상신 → 데이터 소거·불용 처리 → 증적(사진·확인서) 보존
변경 이력	자산별 전체 이력 타임라인 — 등록·이동·구성변경·점검·폐기까지 단일 화면 추적

변경 이력 관리. 소유자·위치·구성의 변경은 신청·결재를 통해 반영되어 대장과 실물의 불일치를 줄이고, Discovery 대사 시 기준 데이터로 사용된다.

재고 · 계약 · 라이선스 관리

재고 · 재물조사

화면	기능
재고 현황	유형·부서·위치별 보유 현황, 유희/가용 재고
재물조사 계획	연간/수시 조사 계획, 대상·담당자 지정
조사 수행	바코드/QR 스캔 실사, 모바일 웹 지원
차이 조정	대장 대비 과부족 확인 → 조정 결재 → 반영

계약 · 유지보수

화면	기능
구매 계약	계약-자산 연결, 부속서류·보증기간 관리
유지보수 계약	대상 자산·범위·SLA, 비용 이력
만료 알림	계약·보증·라이선스 만료 임박 자동 메일

SW 라이선스 컴플라이언스 LICENSE COMPLIANCE



라이선스 리스크 양방향 관리. 초과 사용(감사 리스크)과 미사용 보유(비용 낭비)를 동시에 검출한다. 미인가 SW 설치는 Discovery 모듈의 정책 위반 항목으로 연계되어 보안담당에게 통보된다.

탐지 채널 아키텍처 — 6종 병렬 수집

단일 스캔 방식으로는 Shadow IT를 다 찾을 수 없다. 서로 다른 사각지대를 커버하는 6종 채널을 병렬 수집하고, 결과를 자산 지문으로 통합한다.

채널	발견 대상	방식	비고
01 네트워크 능동 스캔	미등록 단말·서버·IoT 장비	대역 스캔(포트·서비스·OS 핑거프린팅), SNMP	스캔 정책·시간대 협의 (운영망 영향 최소화)
02 패시브 트래픽 분석	스캔이 닿지 않는 세그먼트의 활성 장비	DHCP·ARP 테이블 수집, NetFlow/미러링	무중단 — 능동 스캔 보완
03 DNS·프록시·방화벽 로그	미인가 SaaS 사용 (Shadow SaaS)	아웃바운드 도메인 분석 → SaaS 카탈로그 매칭	CASB 경량 대체 접근
04 EDR·엔드포인트 연계	설치 SW, USB, 로컬 가상머신	기존 EDR·백신 콘솔 API 연동	신규 에이전트 배포 없이 시작
05 클라우드 API	미관리 클라우드 리소스·계정	CSP API (AWS Config · Azure Resource Graph 등)	부서·개인 계정 발견은 조직 정책 병행
06 AD/IdP·SSO 로그	미인가 앱 OAuth 연동, 휴면 계정	AD/Entra ID 로그, SSO 앱 카탈로그 대조	계정 기반 Shadow IT

기존 인프라 재활용 우선. NAC·EDR·프록시·AD 등 이미 보유한 시스템의 데이터를 커넥터로 수집하는 것을 기본으로 하여, 도입 초기부터 에이전트 추가 배포 없이 가시성을 확보한다. 능동 스캔은 정책 협의 후 단계적으로 확대한다.

CMDB 대사 · 처리 워크플로

발견 → 편입 폐쇄 루프 CLOSED LOOP

SOURCES — 6 CHANNELS



그림 3 — Shadow IT 발견 → 편입 폐쇄 루프. 대사는 자산 대장을 기준 데이터로 참조하고, 편입 결과가 다시 대장으로 환류된다.

대사 결과별 처리 RECONCILIATION OUTCOMES

대사 결과	의미	처리
등록 · 일치	대장에 있고 실측 정보 일치	최종 확인 일시 갱신 (생존 신호)
등록 · 불일치	대장에 있으나 위치·소유자·구성 상이	차이 항목 표시 → 자산담당 확인 · 대장 보정
미등록 (Shadow IT)	실측되나 대장에 없음	소유자 확인 요청 → 편입(결재) 또는 격리 요청
미확인 (유령 자산)	대장에 있으나 일정 기간 실측 없음	유휴·분실 후보 → 재물조사 대상 자동 편성

외부 공격표면 탐지 — 조직 밖으로 노출된 미인지 자산

앞의 6종 채널이 사내망 자산을 찾는다면, 외부 공격표면 탐지는 **조직 도메인에서 외부로 노출된 미인지 자산**(잊힌 서브도메인, 방치된 서버, 노출된 관리 콘솔, 유출 계정 등)을 조직 외부의 관점에서 발견한다. 인터넷에 공개된 정보만으로 수집하는 **수동(Passive)** 방식과 대상에 직접 접속·질의하는 **능동(Active)** 방식을 조합한다.

PASSIVE
수동 — 대상 인프라에 접촉하지 않음

- 인증서 투명성(CT) 로그 · 웹 아카이브
- 검색엔진 도킹 · DNS 인텔리전스
- 위협 인텔리전스(OSINT·IOC) 상관
- 다크웹 크롤 · 유출/침해 데이터 수집

ACTIVE
능동 — 대상에 직접 질의·접속

- DNS 브루트포스 · 순열 · 레코드 질의 · 존 트랜스퍼
- 역DNS · CIDR 대역 스캔
- 포트·서비스·취약점(CVE) 스캔
- 기본·취약 크리덴셜 점검

수동 외부 수집 PASSIVE COLLECTION

방법	기법	데이터 소스 · 산출
인증서 투명성 (CT)	공개 CT 로그에서 발급 인증서의 호스트명·메타데이터 수집(대상 무접촉). 와일드카드 제거·중복 제거·유효성 검증	서브도메인, 인증서 항목(발급 CA·유효기간). 유효기간으로 생존 여부 추정
웹 아카이브	인터넷 아카이브에서 과거 관측된 호스트명·URL 조회(수집 연한 지정)	과거 노출 서브도메인(생존 확인 전까지 비활성 표기)
검색엔진 도킹	검색엔진 결과에 도크 질의(site::inurl: 등) 후 서브도메인 정규식 추출. User-Agent 로 테이션·프록시·백오프 재시도	공개 색인된 서브도메인
DNS 인텔리전스	외부 DNS 인텔리전스 서비스에서 알려진 서브도메인·레코드 조회	서브도메인·DNS 레코드

수동 우선 원칙. 대상에 흔적을 남기지 않는 수동 수집으로 먼저 자산 후보를 넓게 확보한 뒤, 능동 탐지로 생존·서비스·취약점을 확인한다. 능동 스캔은 대상·강도·시간대 정책 협의 후 수행한다.

외부 공격표면 탐지 — 능동 탐지 · 위협 인텔리전스

DNS 기반 능동 탐지 ACTIVE DNS

다수의 공개 리졸버 풀을 라운드로빈하는 대량 병렬 질의로 가장 넓은 발견 표면을 만든다. 브루트포스 → 순열 생성 → 대량 브루트포스 → 존 트랜스퍼 → 레코드 분석을 파이프라인으로 연결한다.

방법	기법 · 산출
서브도메인 브루트포스	사전 기반 서브도메인 추정(사용자 사전 → 관리 사전 → 기본 사전). 대량 모드는 지역·기술·숫자·다단계 변형으로 최대 수만 건 확장
순열 생성	알려진 서브도메인에 환경(dev/stg/prod)·접두·접미·숫자·구분자·키워드를 조합 후 실시간 해석
역DNS · CIDR 스캔	IP의 PTR 호스트명 조회, IP 대역 전체 열거 후 알려진 도메인 교차 확인 및 동시 PTR 조회
존 트랜스퍼 · 레코드 분석	네임서버 확인 후 AXFR 시도, 거부 시 A/AAAA/CNAME/MX/NS/TXT/SRV-SOA/CAA 질의로 대체. 레코드 값에 포함된 범위 내 호스트명 추출. 와일드카드 DNS 탐지로 오탐 억제

포트·서비스·취약점 스캔 ACTIVE

- 2단계 스캔 — 고속 오픈 포트 스윕 → 서비스·버전 정밀 분석
- 서비스·제품·버전 핑거프린트, 취약점 스크립트로 CVE-CVSS-심각도 추출(버전 휴리스틱 보완)
- 산출: 오픈 포트, 서비스/버전, CVE(심각도)

인증 취약점 점검 ACTIVE

- 오픈 확인된 포트에 한해 기본·취약 크리덴셜 점검
- SSH·DB(PostgreSQL·MySQL)·FTP·HTTP Basic·Redis·SMTP 등, 동시성 제한
- 산출: 취약·기본 크리덴셜 노출(서비스별)

위협 인텔리전스 PASSIVE

- OSINT 위협 인텔리전스 연계 — 위협 행위자 귀속, 표적 정보, 네트워크·호스트·해시 IOC 상관
- 신규 자산 발견보다 알려진 자산에 위협 맥락 부여

다크웹 · 유출 수집 PASSIVE CTI

- 다크웹 크롤 — Tor 기반 .onion 탐색, 랜섬웨어 유출 사이트 피해 목록, 페이스트 사이트 분류
- 유출·침해 수집 — 유출 계정·스틸러 로그, 코드 저장소 노출 시크릿, 침해 이메일
- 도메인 기준으로 고객 매칭 후 신뢰도 점수화·중복 제거

발견 자산의 편입. 외부에서 발견된 노출 자산도 내부 6채널 결과와 동일하게 자산 지문으로 통합되고, CMDb 대사(그림 3)를 거쳐 소유자 확인·편입 또는 노출 차단·격리 조치로 이어진다. 재탐지는 도메인별 주기(스케줄러)로 자동 반복된다.

AI 기능 구성 — 5대 기능

기능	적용 기술	동작
01 자산 자동분류·정규화	LLM 분류 · 규칙 하이브리드	스캔 배너·설치 SW 목록·모델명 문자열을 표준 자산 유형·제조사·모델로 자동 매핑 — 발견 자산의 수기 분류 작업 제거
02 이상 자산 행위 탐지	비지도 이상탐지 (프로파일 기반)	자산별 평시 프로파일(트래픽·접속 시간대·설치 SW 변화) 대비 이탈 탐지 — 미인가 SW 설치, 휴면 자산의 갑작스런 활동, 서버의 비정상 외부 통신
03 수명주기·교체수요 예측	생존 분석 · 회귀 모델	장애 이력·사용 연한·성능 데이터 기반 교체 시점 예측, 연간 교체수요·예산 추정 리포트
04 취약점 노출 우선순위	스코어링 (자산 중요도 × 노출도)	발견된 노출 서비스·EOL OS·미패치 SW를 자산 중요도와 결합해 조치 우선순위 산출 — 취약점 스캐너 결과 연계 시 자산 컨텍스트 부여
05 라이선스 최적화 제안	사용 패턴 분석	장기 미사용 라이선스 회수 후보, 중복 기능 SaaS 통합 후보, 갱신 협상 근거 데이터 제안



그림 4 — AI 제안·확인·환류 구조. AI 제안은 담당자 확인과 결재를 거쳐 반영되고, 승인·반려 결과는 재학습에 사용된다.

AI는 결정하지 않고 제안한다. 분류·이상 탐지·예측·우선순위 등 AI가 만든 결과는 판단 근거와 함께 담당자 화면에 제안 형태로 표시되고, 대장 반영이나 격리 같은 실제 조치는 담당자가 확인하고 결재해야 실행된다. 담당자의 승인·반려 결과는 다시 학습에 반영되어 시간이 지날수록 제안 정확도가 높아진다.

AI 어시스턴트 · 리포트 자동화

자연어 자산 질의 RAG

- 자산 대장·발견 자산·계약·이력을 대상으로 **자연어 질의** — 결과는 화면 데이터와 동일한 권한 필터 적용
- 질의 예시:
 - "이번 달 새로 발견된 미등록 단말 중 서버 대역에 있는 것은?"
 - "내년 1분기 보증 만료되는 네트워크 장비 목록"
 - "A부서에서 쓰는 미인가 SaaS와 월 추정 사용자 수"
- 응답에 **근거 데이터 링크**(해당 화면·레코드) 첨부 — 답변 검증 가능

리포트 자동 생성

- 주간 Shadow IT 발견 브리핑, 월간 자산 현황·라이선스 리포트 자동 작성(결재 첨부용 엑셀·문서)
- 재물조사 결과 요약, 감사 대응 자료 초안 생성

AI 실행 환경 옵션 DEPLOYMENT

옵션	구성
온프레미스 LLM	사내 GPU 서버에 오픈 모델 배치 — 자산 데이터 외부 반출 없음 (망 분리 환경 기본안)
외부 API 연계	비식별 처리 후 상용 LLM API 활용 — 보안성 검토 전제
하이브리드	분류·질의는 온프레미스, 대량 배치 분석만 선별 외부 처리

AI 거버넌스

- AI 제안·질의·응답 전체 **감사 로그** 보존
- 모델·프롬프트 버전 관리, 성능(분류 정확도) 정기 리포트
- 권한 밖 데이터는 질의 컨텍스트에서 원천 배제

망분리 환경 기본 대응. AI 기능은 온프레미스 LLM 구성을 기본안으로 설계되어, 자산·구성 정보가 외부로 나가지 않는 조건에서 자연어 질의와 자동 분류를 제공한다.

시스템 연동 아키텍처

COLLECT — API · LOG



그림 5 — 시스템 연동 구성. 보안·인프라 시스템에서 수집(REST API · 로그 · DB)하고, 판정 결과를 조치 채널로 되돌려 보낸다.

연동 대상	방식	용도
NAC	REST API	단말 인증·미인증 목록 수집(발견 소스), 미확인 자산 격리 요청(조치 채널)
EDR · 백신 콘솔	REST API	단말·설치 SW 인벤토리 수집 — 라이선스 대사·미인가 SW 검출 원천
AD / Entra ID	API · 로그	계정·단말·부서 매핑, OAuth 앱·휴면 계정 발견, 소유자 확인 대상 판별
프록시·방화벽·DNS	로그 수집	아웃바운드 도메인 → SaaS 카탈로그 매칭 (Shadow SaaS 발견)
CSP (AWS·Azure 등)	CSP API	클라우드 리소스·계정 인벤토리 수집, 미관리 리소스 발견
그룹웨어 · 인사	SAML · API	SSO 인증, 결재 연동, 조직·인사 정보 (소유자 확인 메일 발송 기준)
ITSM · 구매	REST API	SR·발주 정보 연계 — 도입 예정 자산의 사전 등록

기술 스택 · 보안성 · 사양 요약

PLATFORM

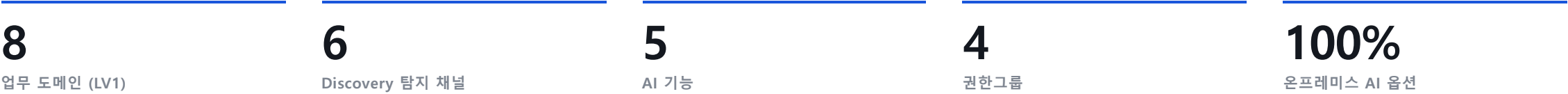
플랫폼 · 인프라

- **배포** — 사내 온프레미스 (웹 기반)
- **DB** — RDB (자산 대장) + 로그 스토어 (수집 데이터) 분리
- **AI** — 온프레미스 LLM · ML 파이프라인 (GPU 서버 옵션)
- **수집** — 커넥터 프레임워크 (REST · 로그 · DB · 스캐너)
- **연동** — SAML SSO · REST API

SECURITY

보안 · 컴플라이언스

- **인증** — SAML 기반 SSO
- **접근통제** — 메뉴·기능 권한관리 (AI 질의 포함)
- **DB 암호화** — 자격증명·민감 컬럼 암호화
- **감사** — 전자결재·자산 이력·AI 로그 추적성
- **스캔 안전장치** — 대역·시간대·강도 정책 통제



대장 정합성과 변경 이력. 발견 → 소유자 확인 → 편집/격리 흐름과 수명주기 전 구간의 결재·이력을 통해, 대장과 실물의 차이를 줄이고 자산 변경을 추적할 수 있도록 돕는다. AI는 이렇게 쌓인 데이터를 활용해 분류·예측·질의를 자동화한다.